CHAPTER 1 STUDY GUIDE

Today's Security Professional



CS Objectives (CIA Triad)

- **Confidentiality:** Ensures unAUs (unauthorized users) cannot access sensitive data.
- **Integrity:** Ensures no unAUs modify systems or stored information.
- **Availability:** Ensures information and systems are ready for legitimate users.
- **Non-Repudiation:** Prevents an actor from denying an action (e.g., Digital Signatures).

CS Threats (DAD Triad)

- **Disclosure:** Exposure to unAUs (AKA data loss, data exfiltration).
- **Alteration:** Unauthorized modification (fraudulent transactions, typos).
- **Denial:** Disruption of legitimate access to info/systems (e.g., DDoS).

Security Controls: Categories & Types

Category	Definition & Operational Focus	Practical Examples
Technical	Enforces CIA rules directly within digital and network systems.	Firewalls, Intrusion Prevention (IPS), Encryption
Operational	Day-to-day administrative and human security procedures.	User access reviews, Security log monitoring
Managerial	Procedural mechanisms focused on strategic governance & risk.	Risk assessment, Security in orgs, Change management
Physical	Tangible mechanisms governing assets in the physical world.	Fences, Locks, Lighting, Alarms

Control Types: Preventative Firewall, Encryption • Deterrent Guard dogs, Barbed wire • Detective IDS (Intrusion Detection) • Corrective Restoring backups • Compensating Mitigating risk from policy exceptions • Directive Policies & Procedures

Organizational Risk Categories

- **Financial:** Direct monetary harm (repairs, lost equipment, revenue loss).
- **Reputational:** Negative publicity damaging business partner goodwill.
- **Strategic:** Prevents meeting major objectives; threatens company existence.
- **Operational:** Impedes daily workflows, causing delays and long workarounds.
- **Compliance:** Running afoul of regulations (e.g., losing PHI violates HIPAA).

Data Protection & Loss Prevention (DLP)

- **Data States:** Rest (stored), Transit (over network), Use (active memory).
- **Agent vs. Agentless:** Endpoint software (blocks USBs) vs. Network appliances.
- **DLP Mechanisms:** Pattern Matching (format/#, "Top Secret") & Watermarking tags.
- **Data Minimization:** Hashing, Tokenization (lookup table), Masking (*, X).
- **Access & Boundary:** Geographic/Role restrictions, Segmentation, Network Isolation.

CHAPTER 2 STUDY GUIDE

Cybersecurity Threat Landscape

Threat Classification Pillars

- **1. Internal vs. External:** Insider personnel vs. outside adversaries.
- **2. Sophistication / Capability:** Script kiddies to elite cyber warfare.
- **3. Resources & Funding:** Individual hobbyists to nation-state treasuries.
- **4. Intent & Motivation:** Financial theft, hacktivism, espionage, chaos, war.

The "Hats" of Hackers

- **Authorized:** Hired/employed to find vulnerabilities to correct them.
- **Semi-Authorized:** Discovers flaws without malice, but lacks prior authorization.
- **Unauthorized:** Exploits vulnerabilities for personal gain or malice without authorization.

Threat Actor Taxonomy

Actor Type	Capability & Resource Profile	Motivations, Tactics & Examples
Unskilled Attackers	Low skill, minimal experience; relies on purchased tools/scripts.	High-volume, indiscriminate attacks; automated scanning.
Hacktivists	Variable capability; highly determined, willing to take high risks.	Belief in perceived "greater good"; defacement, leaks (*Edward Snowden leaked classified docs in 2013).
Organized Crime	Moderate-to-high capability, highly organized, well-funded.	Financial gain: Ransomware, BEC fraud, dark web trading, money mules, cryptocurrency laundering.
Nation-State (APTs)	Advanced Persistent Threats; elite skill, national funding.	Zero-Day attacks, espionage, sabotage (*Stuxnet: joint US/Israel operation against Iranian nuclear centrifuges).
Insider Threats	Employees, contractors, or vendors holding authorized access.	Low resource need due to existing access; mitigated via behavioral assessments. Risks of *Shadow IT* (e.g., Dropbox).
Competitors	Corporate espionage agents; sponsored research operations.	Theft of proprietary software, customer lists, and product roadmaps via dark web brokers or insiders.

Threat Vectors & Attack Surfaces

Vector: Means of access • **Surface:** Vulnerable target.

- **Message-Based:** Phishing, spam email, SMS (Smishing), voice (Vishing).
- **Network Vectors:** Unsecured wall jacks, rogue WiFi, Bluetooth.
- **System Vectors:** OS misconfigurations, open ports, legacy software.
- **Removable Media & Files:** Embedded code in files; dropped infected USBs.
- **Cloud & Supply Chain:** Misconfigured roles; compromising upstream vendors.

Threat Data & Intelligence

- **OSINT Feeds:** Senki.org, MISP project, AT&T OTX, Threatfeeds.io; Government (CISA, DoD Cyber Crime, AIS); Vendor blogs (Microsoft, Cisco).
- **Proprietary Feeds:** Commercial vendor intelligence & geographic threat maps.
- **Evaluation:** Tested for *Timeliness*, *Accuracy*, and *Relevance*.
- **Confidence Score:** Confirmed (90–100), Probable (70–89), Possible (50–69), Doubtful (30–49), Improbable (2–29), Discredited (1).
- **Standards: STIX** (structured language), **TAXII** (HTTPS exchange), ISACs.

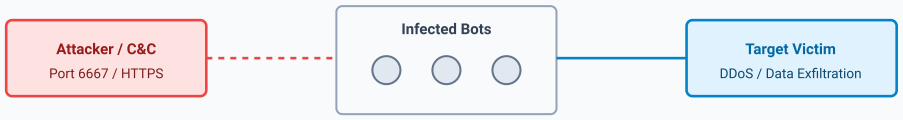
CHAPTER 3 STUDY GUIDE

Malicious Code & Analysis

Malware: Software designed to cause harm to systems, devices, networks, or users. It gathers information, provides illicit access, and performs unwanted, destructive operations.

Taxonomy of Malicious Software

Malware Class	Operational Mechanism	IoCs & Mitigations
Ransomware	Takes over system, encrypts vital files, and demands ransom. Delivered via email, exposed RDP, or vulnerable web services.	C&C traffic, abnormal admin tool activity, bulk file encryption notices. *Primary Defense: Isolated offline backups.*
Trojans	Disguised as legitimate utilities. Remote Access Trojans (RATs) provide backdoors and hijack legitimate remote management tools.	Signatures, rogue C&C connections, new file drops (*Triada Trojan disguised as modified WhatsApp for ads/theft).
Worms	Self-installing, self-propagating code spreading without user interaction over networks, vulnerabilities, or infected USBs.	High traffic bursts, cmd.exe / msiexec injection. *Raspberry Robin (USB to Windows tools) & *Stuxnet (nuclear worm).
Viruses	Self-replicating software that executes only *after* user activation. Subtypes: Memory-Resident, Non-Resident, Boot Sector, Macro, Email.	Abnormal disk activity, registry persistence. Fileless variants reinfect upon reboot via registry keys. Requires endpoint patching.
Spyware & Keyloggers	Silently monitors browsing, keystrokes, and credentials via kernel hooks, OS APIs, or direct memory scraping.	Browser injection, hidden background processes, regular data exfiltration bursts. *Mitigations: MFA, Anti-malware.*
Rootkits	Maintains persistent stealth access by subverting OS kernel drivers and Master Boot Record (MBR) startup code.	Hidden open ports, reverse tunnels. Best detected by booting from a clean, trusted external environment.



Auxiliary Threats & Persistence

- **Logic Bombs:** Dormant code that detonates upon specific logic conditions (date, employee termination); detected via static code reviews.
- **Bloatware:** Unwanted pre-installed OEM software that wastes storage and expands the attack surface; remove before deployment.

Analyzing Malware Code

- **Online Feeds:** VirusTotal, public hash repositories.
- **Sandboxing:** Safe execution inside an isolated virtual sandbox.
- **Manual Analysis:** Static disassembly and source code review.

CHAPTER 4 STUDY GUIDE

Social Engineering & Password Attacks

Human Vectors & Social Engineering Principles

Principles of Psychological Influence

- **Authority:** Social conditioning to comply with perceived superiors/executives.
- **Intimidation:** Coercion through threats of disciplinary or operational fallout.
- **Consensus (Social Proof):** Validating actions by citing widespread peer behavior.
- **Scarcity:** Fabricating perceived shortages to compel hurried decisions.
- **Familiarity & Liking:** Exploiting interpersonal warmth and common connections.
- **Trust:** Cultivating personal rapport that overrides suspicion.
- **Urgency:** Fabricating artificial deadlines to bypass critical thinking.

CISA 5-Step "TRUST" Process

Defeating **MDM** (Mis-, Dis-, and Mal-information):

1. **T — Tell your story:** Communicate directly and early.
2. **R — Ready your team:** Align spokespeople on verified facts.
3. **U — Understand & assess:** Evaluate MDM reach and vectors.
4. **S — Strategize response:** Deploy coordinated counter-messaging.
5. **T — Track outcome:** Monitor audience perception changes.

Social Engineering Exploitation Techniques

Technique	Mechanisms, Targets & Characteristics
Phishing / Smishing / Vishing	Fraudulent solicitation of credentials, PII, and financial information via Email, SMS text messaging, or Voice phone calls.
Whaling & BEC	Whaling targets senior executives. Business Email Compromise (BEC) tricks finance staff into fraudulent wire transfers via spoofed executive/vendor emails.
Pretexting & Impersonation	Inventing a fabricated persona or scenario (e.g., external auditor, IT helpdesk) to establish false credibility and justify illicit access requests.
Watering Hole Attack	Compromising a third-party website frequently visited by members of the targeted organization.
Brand Impersonation & Typosquatting	Impersonating reputable corporate communications; registering misspelled domain variants (e.g., *examp1e.com*) to harvest user logins.
Information Classifications	**Misinformation:** False info shared without malicious intent • **Disinformation:** Deliberate lies designed to deceive • **Mal-information:** Truthful info used maliciously out of context.

Password Attack Methodologies

Brute Force Attacks
Systematically calculating and testing every possible character combination against a single username. Mitigated via account lockout thresholds.

Password Spraying
Testing one or two common passwords (e.g., *Company2024!*) across thousands of user accounts to circumvent per-user lockout limits.

Dictionary Attacks
Automated matching against curated wordlists, common passwords, and breached password dumps (e.g., *John the Ripper*). Mitigated via MFA.

CHAPTER 5 STUDY GUIDE

Security Assessment, Testing & Auditing

Vulnerability Scanning Methods

- **Network (Uncredentialed):** Probes from distance; results masked by firewalls/IPS; higher false positive/negative rates.
- **Credentialed:** Authenticates directly to server OS and services to audit exact patch levels and configurations.
- **Agent-Based:** Local software executes inside-out audits.
- **Code Testing:** Static (SAST), Dynamic (DAST), Interactive (IAST), and Fuzzing (submitting random/malformed inputs).

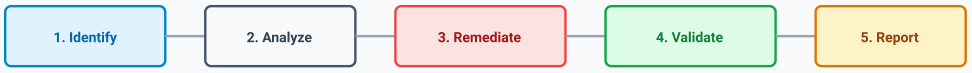
SCAP Protocol Suite

- **CVE:** Common Vulnerabilities & Exposures (flaw naming).
- **CVSS:** Standardized numerical 0–10 severity rating.
- **CCE / CPE:** Configuration & Platform enumeration syntax.
- **XCCDF / OVAL:** XML checklist reporting & low-level testing logic.
- **Scanning Tools:** Nessus, Qualys, Nexpose, OpenVAS.

CVSS v3.0 Base Metric Reference

Metric Group	Sub-metrics & Scoring Values	Rating Scale
Exploitability	**AV:** P (0.20), L (0.55), A (0.62), N (0.85) • **AC:** H (0.44), L (0.77) **PR (Scope=U):** H (0.27), L (0.62), N (0.85) • **UI:** R (0.62), N (0.85)	**0.0:** None **0.1–3.9:** Low **4.0–6.9:** Medium **7.0–8.9:** High **9.0–10.0:** Critical
Scope (S)	**U (Unchanged):** Impacts only local component authority. **C (Changed):** Expands impact beyond immediate managing authority.	
Impact	**Confidentiality (C):** N (0.00), L (0.22), H (0.56) **Integrity (I):** N (0.00), L (0.22), H (0.56) • **Availability (A):** N (0.00), L (0.22), H (0.56)	

CVSS Formula: `ISS = 1 − [(1 − C) × (1 − I) × (1 − A)] | Exploitability = 8.22 × AV × AC × PR × UI`
Example Vector: `CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N ⇒ ISS = 0.56 | Impact = 3.60 | Exploit = 3.89 ⇒` **`Base Score = 7.5 (High)`**



Penetration Testing & RoE

- **Philosophy:** Adopts attacker mindset; needs only 1 flaw to succeed.
- **Environments:** Known (White Box), Unknown (Black Box), Partially Known.
- **Rules of Engagement (RoE):** Scope, schedule, legal authority, and escalation.
- **Phases:** Reconnaissance → Exploitation → Lateral Movement → Cleanup.

Security Audits & Standards

- **Internal vs. External:** CAE internal reviews vs. Big Four audits (PwC, EY, Deloitte, KPMG).
- **SSAE 18:** Standardized service organization attestation reports.
- **Frameworks:** COBIT (ISACA IT governance) & ISO 27001 / ISO 27002.

CHAPTER 6 STUDY GUIDE

Application Security & DevSecOps



DevSecOps & CI/CD Pipeline

- **DevSecOps:** Embeds security into development toolchains and CI/CD builds.
- **Continuous Integration (CI):** Developers regularly commit code to a shared repository; triggers automated builds and tests.
- **Continuous Deployment (CD):** Automatically rolls validated, tested builds into production without manual intervention.
- **Testing:** SAST (Static Code Analysis), DAST (Dynamic Running Analysis), and Fuzzing (submitting unexpected random data).

Secure Coding & OWASP Controls

- **OWASP Top Proactive Controls:** Validate input, use parameterized queries, encode data, enforce digital identity, secure data access, handle errors securely, and maintain security logging.
- **API Security:** Interfaces defining client-server exchanges; protected via strong authentication, authorization, rate limiting, and input filtering.
- **Code Signing & Repositories:** Private key code signatures verify authenticity; centralized repositories track version rollbacks.

Application Vulnerabilities & Exploitation Methods

Vulnerability Type	Operational Mechanism & Attack Vector	Key Defenses & Mitigations
Injection Attacks SQLi Command LDAP/XML	Untrusted input interpreted as commands (e.g., `' OR 1=1--` or blind timing `WAITFOR DELAY '00:00:15'`). Manipulates databases or host OS.	**Parameterized Queries / Stored Procedures**, Server-side Allow-Listing, input escaping.
XSS & Request Forgery XSS CSRF SSRF	**XSS:** Injects HTML/scripts executed by user browser. **CSRF:** Exploits user credentials to send unauthorized requests. **SSRF:** Forces server to query non-public internal URLs.	Context-aware output encoding, anti-CSRF synchronizer tokens, strict WAF rules, URL allow-listing.
Authorization Flaws IDOR Directory Traversal	**IDOR:** Directly tampering with database record IDs in URL/POST requests. **Directory Traversal:** Blind navigating (`../`) to access unauthorized files, LFI/RFI, or Web Shells.	Server-side authorization checks, blocking path operators (`..`, `/`), disabling remote file execution.
Memory & Race Flaws Buffer Overflow TOCTTOU	**Buffer/Integer Overflow:** Writing past memory boundaries. **TOCTTOU:** Race condition between Time-of-Check and Time-of-Use.	Bounds checking, memory-safe languages, re-evaluating permissions immediately at access time.

Session Attacks & Defenses

- **Cookie Hijacking:** Intercepting session cookies; mitigated via `Secure` and `HttpOnly` cookie flags.
- **NTLM Pass-the-Hash:** Harvesting Windows password hashes to replay across Active Directory without cracking plaintext.
- **Unvalidated Redirects:** Arbitrary redirection abusing user trust.

Automation, Scripting & SOAR

- **SOAR:** Security Orchestration, Automation, & Response; connects threat feeds and automates repeatable alert triage.
- **Scripting:** Python, Bash, and PowerShell for automated log analysis, user provisioning, guardrails, and rapid response.
- **Considerations:** Script complexity, technical debt, and single points of failure.

CHAPTER 7 STUDY GUIDE

Cryptography & Public Key Infrastructure (PKI)

Historical Ciphers & Fundamentals

- **Substitution:** Swapping characters (*Caesar Cipher* / ROT13 shifts 13; *Vigenère* uses keyword lookup matrix).
- **Transposition:** Scrambles letter positions in blocks (*Columnar Transposition* writes rows, reads columns).
- **The Enigma Machine:** WWII rotor cipher defeated by Alan Turing (Project Ultra).
- **Kerckhoffs' Principle:** System must remain secure even if everything about it is public, *except the key*. Rejects security through obscurity.

Data-at-Rest & Database Encryption

- **Full-Disk Encryption (FDE):** Encrypts entire drive including OS; accessible once booted.
- **Partition & File:** Segregates sensitive volumes or individual files.
- **Database Encryption:** Transparent Data Encryption (TDE, entire DB), Column-Level (CLE, specific sensitive columns), and Record-Level.
- **Non-Repudiation:** Guaranteed *only* via asymmetric keys.

Symmetric vs. Asymmetric Architectures



Attribute	Symmetric Cryptography	Asymmetric Cryptography
Key Structure	Single shared secret key for encryption & decryption.	Public key (shared openly) & Private key (kept secret by owner).
Performance & Scale	Extremely fast; poor key scalability: $n(n - 1) / 2$ keys.	High compute overhead; highly scalable: $2n$ total keys.
Core Algorithms	**AES** (128/192/256-bit, 10/12/14 rounds), 3DES, DES.	**RSA** (prime factorization), **ECC** ($y^2 = x^3 + ax + b$).
Primary Usage	Bulk data encryption at rest and in transit.	Key exchange, digital signatures, certificates, identity verification.

`Diffie-Hellman Key Exchange (1976):`
`1. Agree on public prime $p$ & generator $g$ ($1 < g < p$).`
`2. Rick: $R = g^r \bmod p$; Sue: $S = g^s \bmod p$. Exchange $R$ and $S$.`
`3. Rick computes $K = S^r \bmod p$; Sue computes $K = R^s \bmod p$. Both hold identical secret key $K$.`

Golden Rules of Asymmetric Keys

- **Confidentiality:** Encrypt with **Recipient's Public Key**.
- **Decryption:** Decrypt with **Recipient's Private Key**.
- **Digital Signature:** Sign with **Sender's Private Key**.
- **Signature Verification:** Verify with **Sender's Public Key**.

Hashes, Signatures & Formats

- **Hashing:** SHA-1 (160-bit), SHA-2 (256/512-bit), SHA-3 (Keccak); MD5 deprecated due to collisions.
- **HMAC:** Hash with symmetric shared key; integrity but no non-repudiation.
- **Formats: DER** (.der binary), **PEM** (.pem Base64 ASCII), **PFX** (.pfx/.p12 cert + private key), **PKCS#7** (.p7b certs only).

PKI, Certificate Revocation & Attacks

- **X.509 Fields:** Subject CN, Issuer CA, Validity, Public Key, SANs.
- **Revocation: CRL** (periodic list) vs. **OCSP** (real-time query); **OCSP Stapling** caches status on web server for 24h.
- **Cryptanalysis:** Birthday Attack ($1.17\sqrt{n}$ collision probability), Rainbow tables (prevented via salting & PBKDF2), Downgrade attacks.

CHAPTER 8 STUDY GUIDE

Identity & Access Management (IAM)

Identity & Authentication Frameworks

- **Identity Identifiers:** Usernames, X.509 Certificates, Hardware Tokens (USB/BT), SSH Keys, Smartcards (chip-and-PIN).
- **EAP:** Extensible Authentication Protocol; common wireless framework.
- **CHAP:** Challenge Handshake Authentication Protocol; 3-way challenge handshake preventing cleartext replay.
- **Kerberos:** Untrusted network authentication using tickets; components: *Principal*, *Instance*, and *Realm*.

SSO, Federation & Standards

- **Single Sign-On (SSO):** Log in once to access multiple independent systems without repeated credentials.
- **LDAP:** Lightweight Directory Access Protocol (TCP 389, LDAPS TCP 636) for centralized directory lookups.
- **SAML:** XML-based open standard for exchanging authentication and authorization assertions across security domains.
- **OpenID vs. OAuth:** OpenID for *Authentication* ("Log in with Google"); OAuth for *Authorization* (granular access tokens).

Network Access Control & 802.1X Flow



Authentication Factors & Access Control Models

Something You Know
Passwords, PINs, Security questions.

Something You Have
Smartcards, USB/BT tokens, Authenticator apps.

Something You Are
Biometrics (fingerprint, iris, facial, gait).

Somewhere You Are
GPS geolocation, trusted corporate IP subnet.

Access Control Model	Enforcement Mechanism	Operational Focus
MAC (Mandatory)	OS kernel enforces access based on subject clearance labels vs. object classification labels.	Highest security (military/classified); set solely by security admin.
DAC (Discretionary)	Resource owner has complete discretion to grant or delegate access permissions to others.	High flexibility; common in standard commercial operating systems.
RBAC (Role-Based)	Permissions assigned to organizational roles. Users are assigned to authorized roles.	Simplifies enterprise user administration; enforces least privilege.
RuBAC (Rule-Based)	Access granted or denied based on global deterministic rules and Access Control Lists (ACLs).	Firewall rule bases; port and protocol filtering.
ABAC (Attribute-Based)	Dynamic policies evaluated using multi-variable user, resource, and environmental attributes.	Highly granular, context-aware; high policy complexity.

PAM & Account Governance

- **Privileged Access Management (PAM):** Just-in-Time (JIT) access elevations; shared admin Password Vaulting; Ephemeral self-expiring accounts.
- **NIST Password Rules:** Length over complexity; drop forced expirations; check breached lists.
- **OTP: TOTP** (time-based step) vs. **HOTP** (counter/HMAC-based seed).

File System Controls & AAA

- **File Permissions:** Linux RWX (Owner, Group, World) vs. Windows NTFS DACLs (Read, Modify, Execute).
- **RADIUS vs. TACACS+:** RADIUS (UDP, encrypts password only) vs. TACACS+ (TCP port 49, full-packet payload encryption, separated AAA services).

CHAPTER 9 STUDY GUIDE

Resilience, Redundancy & Physical Security

Resilience & Redundancy Architecture

Goal: Continuity of Operations regardless of disaster or failure.

- **Geographic Dispersion:** 90+ miles separation for disaster recovery sites.
- **Device Separation:** Rack isolation protects from spills and localized accidents.
- **Multipath Networking:** Redundant routes prevent cable cut outages.
- **Power Protection:** Dual-feed hardware, UPS, generators, and Managed PDUs.
- **Clustering & Load Balancing:** Active/Active or Active/Passive high availability.

Backup Schemes & Media

- **Full Backup:** Complete copy; slowest to back up, fastest single restore.
- **Incremental:** Backs up changes since *last backup*; fastest backup, slowest restore (Full + all incrementals).
- **Differential:** Backs up changes since *last full*; moderate speed, faster restore (Full + latest differential).
- **Media:** Tape (bulk/low cost), Disk (NAS/SAN), Cloud; Boot media for untrusted/compromised hosts.

Storage Resilience: RAID Configurations

RAID Level	Operational Mechanism	Trade-Offs & Fault Tolerance Profile
RAID 0 (Striping)	Data striped evenly across all drives in parallel.	Max I/O throughput; 100% capacity. *Not fault-tolerant*; 1 drive loss loses all data.
RAID 1 (Mirroring)	Data duplicated identically across drives.	High read speed; survives 1 drive failure. Disadvantage: 50% capacity overhead.
RAID 5 (Parity)	Data and parity striped across 3+ drives.	Fast reads, balanced capacity cost; tolerates 1 drive failure. Rebuild is slow and taxes I/O.
RAID 10 (1 + 0)	Mirrors data in pairs, then stripes across pairs. 4+ drives.	Combines RAID 0 speed and RAID 1 redundancy; tolerates multi-drive loss if in different pairs.

Disaster Recovery Timeline: RPO vs. RTO



Alternate Sites & Physical Defense

Site Category	Infrastructure & Data State	Operational Readiness & Cost Profile
Hot Site	Fully mirrored facility with identical hardware and real-time live data replication.	Near-instant recovery (minutes to hours); highest operational expense.
Warm Site	Hardware installed and configured; live data not continuously replicated.	Recovery takes hours to days (requires restoring latest backups); moderate cost.
Cold Site	Facility provides physical shell, power, and connectivity; no hardware or data.	Recovery takes days to weeks (hardware procurement needed); lowest recurring cost.

Physical Defense Layers & Sensors

- **Perimeter Defense:** Fences, vehicle bollards, lighting, corporate camouflage.
- **Access Control Vestibule:** Interlocking double-door mantrap preventing tailgating.
- **Sensors:** Infrared (heat), Pressure plates, Microwave Doppler, Ultrasonic vibration.

Exercises & Physical Attacks

- **Exercise Types:** Tabletop discussions, Simulations, Parallel processing, and full Failovers.
- **Attack Vectors:** Physical brute force (broken doors/locks), RFID badge cloning, environmental tampering (HVAC manipulation, sprinkler sabotage).

CHAPTER 10 STUDY GUIDE

Cloud & Virtualization Security

Cloud Characteristics & Benefits

- **On-Demand Self-Service:** Instant provisioning without human intervention.
- **Broad Network Access:** Standard capabilities accessible across any device.
- **Resource Pooling:** Multi-tenant pooling dynamically assigned per demand.
- **Rapid Elasticity & Scalability:** Seamless automated scale up/down.
- **Measured Service:** Transparent metering and pay-per-use billing.

Cloud Roles & Managed Services

- **Cloud Roles:** Cloud Service Providers (CSPs), Cloud Consumers, Cloud Partners/Brokers, Cloud Auditors, and Cloud Carriers.
- **MSPs vs. MSSPs:** Managed Service Providers deliver general IT administration; Managed Security Service Providers (MSSPs) provide specialized security management across cloud and hybrid environments.

Cloud Service & Deployment Models

Service Model	Architecture & Environment Provided	Consumer Control Level
IaaS (Infrastructure)	Provides fundamental compute building blocks: virtual machines, raw storage, network switching, and firewalls.	Controls OS, installed software, runtime, security configs, and data.
PaaS (Platform)	Provides managed execution environments, databases, and development framework toolchains.	Controls deployed applications and application-level configs; no OS access.
SaaS (Software)	Delivers complete, fully managed turnkey applications accessible via web browser or API.	Controls application user settings, data access, and user identity credentials only.
FaaS (Functions/Serverless)	Executes event-driven, micro-billing stateless code functions on demand without provisioning servers.	Authoring and uploading application code functions only; provider runs execution.

Shared Responsibility Model



Standards & Governance Frameworks

- **NIST SP 500-292:** Cloud Computing Reference Architecture; establishes high-level taxonomy, roles, and structural boundaries.
- **CSA CCM (Cloud Controls Matrix):** Published by Cloud Security Alliance; maps cloud-specific controls directly to global regulatory compliance standards.

Edge, Fog & Virtualization Computing

- **Edge Computing:** Data processed locally by remote sensor devices before being transmitted back to central cloud repositories.
- **Fog Computing:** Nearby local gateway nodes aggregate, filter, and process data on the local LAN before sending to the cloud core.
- **Virtualization Security:** Hypervisor isolation, avoiding VM escape vulnerabilities, and managing virtual network segmentation.

CHAPTER 12 STUDY GUIDE

Network Security Architecture & Secure Protocols

OSI Model & Network Design

- **OSI 7 Layers:** 7 App, 6 Presentation, 5 Session, 4 Transport (TCP/UDP), 3 Network (IP/IPsec), 2 Data Link (Ethernet frames), 1 Physical (cables).
- **Design Concepts:** Air-gaps (physical isolation), Logical segmentation (VLANs), High Availability, Fail-closed vs. Fail-open.
- **Modern WAN:** SDN (central software controllers), SD-WAN (multipath connectivity), SASE (converging SD-WAN and cloud security).
- **Zones:** Screened Subnets (DMZ for internet-facing), Intranets (internal only), and Extranets (authorized business partners).

Zero Trust Architecture (ZTA)

Presumes **no implicit trust** regardless of network perimeter location; authenticates and authorizes every access request continuously.

- **Control Plane:** Evaluates context via *Adaptive Identity* (device, posture, location) to execute dynamic access policies.
- **Policy Engine (PE):** Evaluates rules to make access grant/deny decisions.
- **Policy Administrator (PA):** Instructs enforcement points to generate or revoke access tokens.
- **Policy Enforcement Point (PEP):** Data plane gateway intercepting and controlling all session connections.

Zero Trust Architecture (ZTA) Pipeline



Secure Network Protocols Matrix

Legacy Protocol	Original Port	Secure Replacement	Secure Port	Security Mechanism & Operational Benefit
DNS	UDP/TCP 53	**DNSSEC**	UDP/TCP 53	Cryptographic digital signatures prevent cache poisoning and spoofing.
FTP	TCP 21 (20)	**FTPS / SFTP**	TCP 990 / TCP 22	FTPS uses TLS; SFTP encapsulates file transfers inside SSH channels.
HTTP	TCP 80	**HTTPS**	TCP 443	Encapsulates web traffic inside TLS; provides confidentiality & integrity.
IMAP / POP3	TCP 143 / 110	**IMAPS / POPS**	TCP 993 / 995	Wraps incoming email retrieval sessions inside TLS encryption.
LDAP	TCP 389	**LDAPS**	TCP 636	Encrypts Active Directory lookups and credential validation over TLS.
SNMP / Telnet	UDP 161 / TCP 23	**SNMPv3 / SSH**	UDP 161 / TCP 22	SNMPv3 adds auth/encryption; SSH replaces cleartext Telnet console.

Network Security Appliances

- **Firewalls:** Stateless (packet headers), Stateful (connection flows), NGFW (app-aware), and WAF (Layer 7 HTTP).
- **Proxies:** Forward Proxy (masks clients) vs. Reverse Proxy (load balancing, caching, SSL offloading).
- **IDS/IPS:** Signature-based vs. Anomaly-based; Inline blocks traffic, Taps passively replicate streams.
- **Email Security:** SPF (valid sending IPs), DKIM (cryptographic signatures), DMARC (enforces policy alignment).

Deception & Attack Classes

- **Deception Tech:** Honeypots, Honeynets, Honeyfiles, and Honeytokens intentionally left to trace adversaries.
- **Network Attacks:** On-Path (MitM), DNS Poisoning, Domain Hijacking, and Credential Replays.
- **DDoS Vectors:** Volume-Based (Reflected/Amplified NTP/DNS attacks) vs. Protocol-Based (TCP SYN flood attacks).

CHAPTER 13 STUDY GUIDE

Wireless & Mobile Security

Wireless Connection Technologies

- **Cellular:** Geographic cells with towers; treat as external/untrusted network.
- **Wi-Fi:** 2.4 & 5 GHz radio bands extending beyond physical perimeter. Modes: *Ad-hoc* (peer-to-peer) and *Infrastructure* (via WAPs).
- **Bluetooth (2.4 GHz):** Low-power, short-range connections; Security Modes: Mode 1 (No sec), Mode 2 (Service-level), Mode 3 (Link-level), Mode 4 (Secure Simple Pairing).
- **RFID:** Active (powered battery), Semi-Active, and Passive (powered by reader field).
- **GPS & Geolocation:** Used for location-based authentication and geofencing.

Wireless & Mobile Attack Vectors

- **Evil Twin:** Rogue access point spoofing a legitimate network SSID.
- **Rogue AP:** Unauthorized WAP plugged into network without approval.
- **Bluetooth Attacks: Bluejacking** (unsolicited text messages) vs. **Bluesnarfing** (unauthorized data theft from device).
- **Disassociation Attack:** Transmits deauth frames to kick clients off AP to harvest WPA handshakes upon reconnection.
- **Jamming:** Intentional RF interference causing Denial-of-Service.
- **Jailbreaking / Sideloading:** Circumventing OS sandbox controls and installing apps from outside official app stores.

Wireless Network Design & Controller Architecture

Site Surveys & Signal Management

- **Site Survey:** Comprehensive physical walkthrough analyzing coverage, channel interference, and rogue signals.
- **Heat Maps:** Visual diagram of wireless signal strength, dead zones, and overlapping channel allocations.
- **Antenna Placement:** Carefully directing directional vs. omnidirectional antennas to minimize bleed outside facility walls.

WLC Management & Hardening

- **Wireless LAN Controllers (WLC):** Centralized appliance managing AP firmware, RF channels, and client roaming.
- **Hardening:** Change vendor defaults, disable cleartext management protocols (Telnet/HTTP), isolate admin console on dedicated VLAN.

Wi-Fi Protected Access (WPA) Security Standards

Standard	Authentication & Encryption Engine	Security Posture & Vulnerabilities
WEP (Legacy)	RC4 stream cipher with static 24-bit IV.	**Severely Broken:** Weak IVs allow key recovery within minutes.
WPA (TKIP)	Temporal Key Integrity Protocol with RC4 wrapper.	Interim fix for legacy hardware; deprecated due to cryptographic flaws.
WPA2-Personal (PSK)	Pre-Shared Key with **CCMP (AES)** in Counter Mode with CBC-MAC.	Secure encryption, but PSK vulnerable to offline dictionary/brute-force handshake cracking.
WPA2-Enterprise	Requires **802.1X / RADIUS** server authentication for unique user keys.	Enterprise standard; mitigates shared password risks and enables centralized revocation.
WPA3 (Modern)	Simultaneous Authentication of Equals (**SAE**) and 192-bit cryptographic suite.	Protects against offline dictionary attacks; enforces forward secrecy.

Mobile Device Management (MDM)

- **MDM Capabilities:** Remote wipe, full device encryption enforcement, screen-lock pin enforcement, remote tracking, and application allow-listing.
- **Containerization:** Segregating corporate emails/data from personal data on BYOD devices.

Wireless Architecture Topology

- **Point-to-Point (P2P):** Direct directional wireless bridge between two fixed sites.
- **Point-to-Multipoint (P2MP):** Central base station serving multiple remote sites.
- **Mesh Networks:** Self-healing decentralized nodes routing traffic cooperatively.

CHAPTER 14 STUDY GUIDE

Security Monitoring & Incident Response (IR)



Preparing for Incident Response

- **IR Team:** Executive management, InfoSec staff, technical leads, PR/Communications, Legal, HR, and law enforcement liaison.
- **IR Plans & Testing:** Communication plan, Business Continuity (BC), and Disaster Recovery (DR); verified via Tabletop exercises and simulations.
- **Threat Hunting (IoCs):** Investigating account lockouts, concurrent sessions, impossible travel, missing logs, and out-of-cycle bursts.

Cyber Attack Frameworks

- **MITRE ATT&CK:** Matrix of Adversarial Tactics, Techniques, and Common Knowledge; maps observed actions to known threat behaviors.
- **Lockheed Martin Cyber Kill Chain:** Linear progression: Recon → Weaponization → Delivery → Exploitation → Installation → C2 → Actions on Objectives.
- **The Diamond Model:** Adversary, Capability, Infrastructure, and Victim.

Security Monitoring & Log Sources

Log Source	Captured Telemetry & Inspection Data	Incident Detection Focus
Firewall Logs	Accepted/blocked IP traffic, Layer 4 ports, connection states, and Layer 7 inspection.	Inbound port scans, unauthorized egress, C2 callbacks.
OS & Auth Logs	Successful/failed user logins, privilege escalations, account lockouts, user creation.	Brute-force attempts, credential stuffing, pass-the-hash.
Endpoint & App Logs	Software execution, process spawning, file modifications, installer logs, crash dumps.	Malware installation, DLL injection, ransomware activity.
Network & DNS Logs	NetFlow telemetry, router routing tables, DNS resolution lookups, and query logs.	DNS tunneling, fast-flux domains, lateral network movement.

SIEM Architecture & Log Shipping

- **SIEM:** Centralized log aggregation, real-time event correlation rules, alert thresholding, and executive visualization dashboards.
- **Log Forwarding Protocols:** Syslog (UDP 514), Rsyslog, Syslog-ng, and NXLog agents shipping event streams to central repositories.
- **Metadata:** Data describing email headers, file timestamps, and web connections.

Mitigation, SOAR & Root Cause Analysis

- **Remediation Actions:** Application allow/deny listing, network isolation, host quarantine, firewall rule adjustments, and cert revocation.
- **SOAR:** Automates security playbook actions and rapid containment.
- **Root Cause Analysis (RCA):** Identifying fundamental operational flaws using the *Five Whys*, timeline analysis, and cause-and-effect fishbone diagrams.

CHAPTER 16 STUDY GUIDE

Security Governance, Compliance & Risk

Governance Models & Structure

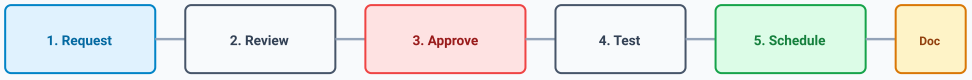
Governance: Sets of procedures and controls established by executive leadership to direct and coordinate security work.

- **Centralized Model:** Top-down policy creation from executive leadership down to subordinate business units.
- **Decentralized Model:** Bottom-up flexibility where individual business units determine controls based on localized requirements.
- **Oversight:** Involves boards of directors, audit committees, and regulators.

Policy Framework Hierarchy

- **Policies (Mandatory):** High-level statements of management intent (e.g., AUP, InfoSec Policy, IR Policy, SDLC Policy, BC/DR Policy).
- **Standards (Mandatory):** Detailed technical requirements (e.g., password length, encryption algorithms, access control lifecycles).
- **Procedures (Mandatory):** Step-by-step instructions (e.g., onboarding/offboarding, change control, IR playbooks).
- **Guidelines (Optional):** Best-practice advisory recommendations.
- **Exceptions:** Documented formal waivers with compensating controls.

Change Management Workflow



Personnel Security Controls

- **Separation of Duties:** Prevents any single individual from having excessive control over critical transactions.
- **Two-Person Control:** Requires two authorized staff to execute sensitive tasks.
- **Job Rotation:** Periodically rotates sensitive roles to reveal fraud.
- **Onboarding & Offboarding:** Provisioning/deprovisioning checklists.
- **NDAs:** Legally protects sensitive proprietary information post-employment.

Third-Party Vendor Agreements

- **MSA:** Master Service Agreement governing overall engagement terms.
- **SLA:** Service Level Agreement defining uptime, response time, and penalties.
- **MOU / MOA:** Documents mutual understanding and shared responsibilities.
- **BPA:** Business Partner Agreement defining revenue and legal duties.
- **Due Diligence:** Questionnaires, right-to-audit, and supply chain review.

Regulatory & Industry Compliance Standards

Regulation / Standard	Governed Sector & Legal Mandate	Key Security Focus
GLBA	U.S. Financial Institutions (banks, lenders, investment firms).	Mandates formal written information security programs.
SOX	U.S. Publicly Traded Corporations.	Requires strong internal controls for financial and IT reporting systems.
GDPR	European Union Data Protection Regulation.	Strict privacy, consent, and data protection rules for EU resident data.
FERPA	U.S. Educational Institutions receiving federal funding.	Protects the privacy and disclosure of student educational records.
ISO 27001 / 27002	International Organization for Standardization.	27001 defines the ISMS framework; 27002 specifies detailed security controls.

CHAPTER 17 STUDY GUIDE

Risk Management, Disaster Recovery & Privacy

Quantitative Risk Analysis

```
Risk Severity = Likelihood of Occurrence × Impact on Org
SLE = Asset Value (AV) × Exposure Factor (EF %)
ALE = Single Loss Expectancy (SLE) × ARO (Annualized Rate)
```

- **Asset Value (AV):** Cost to repair, replace, or lost revenue.
- **Exposure Factor (EF):** Percentage of asset lost in an incident.
- **ARO:** Estimated frequency of occurrence in a given calendar year.

Risk Treatment & States

- **Risk Treatments:**
  - **Mitigation:** Deploying controls to reduce likelihood or impact.
  - **Avoidance:** Altering business practices to eliminate the risk.
  - **Transference:** Shifting financial risk (e.g., cyber insurance).
  - **Acceptance:** Formally accepting risk via documented waivers.
- **Risk States:** *Inherent* (before controls) vs. *Residual* (after controls).
- **Risk Register:** Tracks Risk Owners, Thresholds, and Key Risk Indicators (KRIs).

Business Impact Analysis (BIA) & Recovery Metrics

BIA Metrics & Recovery Thresholds

- **MTBF (Mean Time Between Failures):** Measure of hardware reliability; expected operating lifespan before failure.
- **MTTR (Mean Time to Repair):** Average time required to repair a failed device and restore normal operations.
- **RTO (Recovery Time Objective):** Maximum tolerable system downtime duration acceptable to the business.
- **RPO (Recovery Point Objective):** Maximum acceptable data loss volume measured backwards in time.

Risk Reporting Deliverables

- **Dashboard Reporting:** Real-time visual metrics and heat maps.
- **Ad-Hoc Reporting:** Immediate escalations following specific security incidents.
- **Risk Trend Analysis:** Evaluating historical data to model future risk profiles.
- **Risk Event Reports:** Post-incident analysis documenting damage, impact, and corrective actions taken.

Data Privacy & Classification Frameworks

Information Classifications

- **Government / Military:** Top Secret (Grave damage) • Secret (Serious damage) • Confidential (Damage) • Unclassified
- **Commercial Business:** Highly Sensitive • Sensitive • Internal • Public
- **Sensitive Data Types:** PII, PHI, Financial data, IP/Trade secrets.

Data Privacy Roles (GDPR)

- **Data Subject:** Individual whose personal data is being processed.
- **Data Controller:** Determines the legal basis, purpose, and means of processing.
- **Data Steward:** Ensures data governance and compliance with controller intent.
- **Data Custodian:** Manages technical infrastructure, storage, and safekeeping.
- **Data Processor:** Third-party vendor executing processing on controller behalf.

Information Life Cycle Principles: Data Minimization (collect only the minimal data strictly necessary) • **Purpose Limitation** (use data solely for the explicit reason collected) • **Data Retention Standard** (retain data only as long as business necessity dictates, then securely purge).